



# Marketplace, Guardrails y Calidad

Dirigido a: **Tenant Admin (administrador de tenant) y miembros del tenant con permisos de lectura**

Este manual cubre las tres superficies del panel de administración relacionadas con la extensión y el control de calidad de la plataforma agéntica: el **Marketplace** (catálogo de skills, tools y servidores MCP; instalaciones con sus puertas de seguridad; consentimiento granular de permisos; listings privados del tenant y recursos compartidos entre tenants), el **dashboard de Guardrails** (observabilidad de las políticas de seguridad que se disparan sobre el trabajo del tenant) y el **dashboard de Calidad (Evals)** (cómo puntúan los agentes a lo largo del tiempo).

Todas estas pantallas son **multi-tenant**: cada tenant ve únicamente sus propios datos (catálogo global más sus listings privados, sus instalaciones, sus eventos de guardrails y sus runs de evaluación), aislados por RLS en base de datos. Las acciones de escritura (publicar, instalar, consentir permisos, revocar, compartir) requieren el rol **tenant\_admin**; el resto de miembros pueden consultar en modo lectura. El backend es siempre la fuente de verdad de permisos: aunque un botón fuera visible, la operación solo se aplica si el rol lo permite.

Un concepto atraviesa todo el capítulo del Marketplace: el **nivel de confianza** (verified, community, experimental) de cada listing. El nivel no decide si algo se puede instalar — todo el catálogo es instalable — sino **cuántas puertas de seguridad** impone la instalación: firma criptográfica, análisis estático, prueba en sandbox y consentimiento explícito por permiso. Este manual explica la semántica real de cada puerta.

# Contenido

---

- |    |                                                                  |
|----|------------------------------------------------------------------|
| 01 | Marketplace: pestaña Catálogo y niveles de confianza             |
| 02 | Configuración guiada de la tool Playwright                       |
| 03 | Marketplace: pestaña Instaladas y puertas de la instalación      |
| 04 | Consentimiento granular de permisos de una instalación           |
| 05 | Marketplace: pestaña Compartir (cross-tenant)                    |
| 06 | Marketplace privado: publicar un listing (skill)                 |
| 07 | Marketplace privado: formatos de manifest para tool y MCP server |
| 08 | Dashboard de Guardrails                                          |
| 09 | Dashboard de Calidad (Evals)                                     |

## 1 Marketplace: pestaña Catálogo y niveles de confianza

El Marketplace es el área donde un Tenant Admin gestiona el catálogo de extensiones de su organización. La cabecera muestra el título **Marketplace** con dos botones de acción: **Privadas** (lleva al marketplace privado del tenant) y **Publicar** (atajo al formulario de publicación, visible solo para tenant\_admin). Bajo la cabecera hay tres pestañas: **Catálogo**, **Instaladas** y **Compartir**; la de **Catálogo** está activa por defecto.

El catálogo muestra todos los listings visibles para tu tenant: los del **catálogo global** (etiqueta **global**, visibles para todos los tenants) y los **listings privados propios** (etiqueta **privado**, aislados por RLS: ningún otro tenant los ve jamás). Cada listing aparece como una tarjeta con su nombre, su tipo (**skill**, **tool** o **mcp\_server**), su versión, su nivel de confianza y, si la tiene, una descripción.

El **nivel de confianza** es la pieza central de la política de seguridad del Marketplace. Gobierna las *guardas* que se aplican al instalar, no la disponibilidad:

- **verified** (verde): revisado y **firmado criptográficamente** por el equipo de plataforma (firma Ed25519 sobre el manifest exacto). Instala con fricción mínima: sin consentimiento por permiso y sin sandbox, aunque el análisis estático se ejecuta igualmente como defensa en profundidad (tolera hallazgos hasta severidad media).
- **community** (azul): publicado por terceros, sin firma de plataforma. Requiere **siempre** consentimiento explícito permiso a permiso, análisis estático (solo tolera hallazgos de severidad baja) y una prueba de humo en sandbox.
- **experimental** (ámbar): sin ninguna vejación previa. Máximas guardas: consentimiento por permiso, sandbox y análisis estático en el que **cualquier hallazgo bloquea** la instalación.

Si eres tenant\_admin verás arriba un aviso destacado («¿Tienes una skill o tool interna?») que invita a publicar tus propias skills o tools internas, con el botón **Publicar en el marketplace**. El listing destacado de **Playwright** (tool global verificada) muestra además un botón **Configurar** que abre su configuración guiada (siguiente paso). Si el catálogo está vacío, se muestra un mensaje invitando a publicar la primera skill o tool interna.

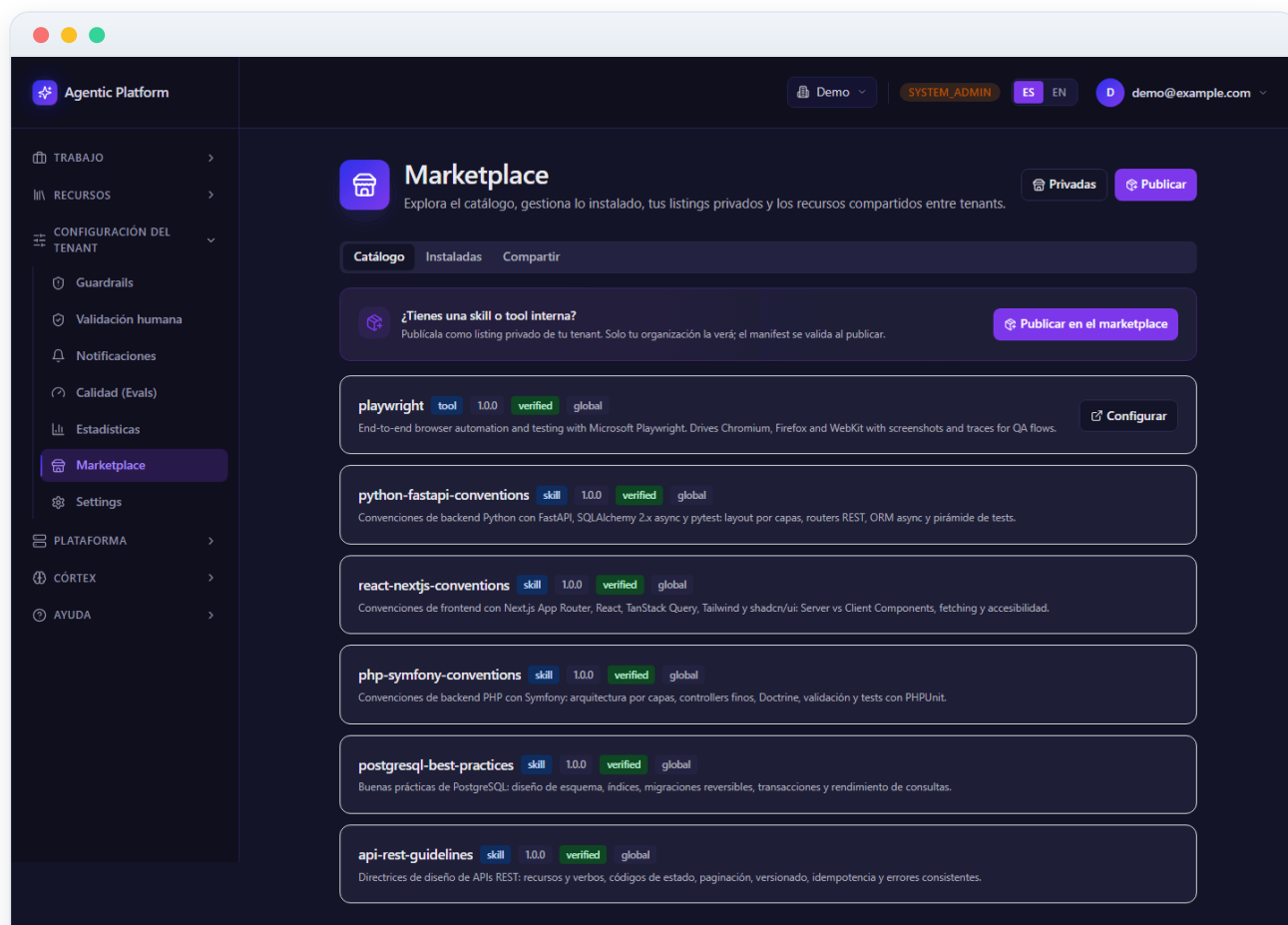


Figura 06.1 — Marketplace: pestaña Catálogo y niveles de confianza

## 2 Configuración guiada de la tool Playwright

Playwright es la tool destacada del catálogo global: permite a los agentes ejecutar pruebas de navegador. En lugar de pedirte YAML libre, la plataforma lee el `config_schema` del propio listing y renderiza este **formulario guiado**. La cabecera muestra el nombre y la versión del listing; el listing en sí es de solo lectura (catálogo global compartido): lo que configuras aquí se persiste en la **instalación de tu tenant**, nunca en el listing.

Los campos del formulario, validados en cliente con las mismas reglas que el backend:

- **Navegadores:** multi-selección entre `chromium`, `firefox` y `webkit`. Debe quedar al menos uno seleccionado o verás el error «Selecciona al menos un navegador».
- **Headless:** conmutador Sí/No. En servidores sin display debe quedar en Sí (el valor por defecto).
- **Screenshots:** *Desactivado, Siempre o Solo en fallo* (por defecto, el más útil para depurar sin llenar disco).
- **Traces:** *Desactivado, Siempre o Retener en fallo* (por defecto).
- **Avanzado:** la **Base URL** contra la que corren los tests (opcional) y el **Timeout (ms)**, que debe ser un entero positivo (por defecto 30000).

Al pie, la tarjeta **Configuración resultante** muestra en vivo el objeto JSON exacto que se guardará en la instalación del tenant, para que puedas revisarlo antes de aplicar. Si tocas un valor inválido, el mensaje de validación aparece encima de la vista previa.

Agentic Platform

Demo SYSTEM\_ADMIN ES EN demo@example.com

### Configuración de Playwright

Configura cómo se ejecuta la tool Playwright (navegadores, headless, screenshots, traces). La configuración se guarda en la instalación de tu tenant. playwright 1.0.0

**Navegadores**

chromium firefox webkit

**Headless** Sí

**Screenshots**

Solo en fallo

**Traces**

Retener en fallo

**Avanzado**

**Base URL**

https://staging.example.test

**Timeout (ms)**

30000

**Configuración resultante**

```
{
  "browsers": [
    "chromium"
  ],
  "headless": true,
  "screenshots": "only-on-failure",
  "traces": "retain-on-failure",
  "base_url": null,
  "timeout_ms": 30000
}
```

Figura 06.2 — Configuración guiada de la tool Playwright

### 3 Marketplace: pestaña Instaladas y puertas de la instalación

La pestaña **Instaladas** lista todo lo que el tenant tiene instalado. Cada instalación se muestra como una tarjeta con el identificador del listing, su versión y una etiqueta de estado: **Habilitada** (operativa), **Deshabilitada** (instalada pero inactiva — típicamente pendiente de consentimiento) o **Revocada** (retirada por un administrador).

Es importante entender qué ocurre **al instalar**. La instalación no es un simple alta: pasa por una cadena de puertas de seguridad que fallan en cerrado, y todo queda registrado en una pista de auditoría inmutable:

- **Análisis estático:** la instalación fresca ejecuta un escaneo del código del artefacto con `bandit` (Python) y `semgrep`. Si algún hallazgo supera la severidad tolerada por el nivel de confianza del listing (media para `verified`, baja para `community`, ninguna para `experimental`), el servidor responde **422 «install blocked by static analysis»**, no se crea ninguna instalación y el intento queda auditado con los hallazgos bloqueantes.
- **Consentimiento:** un listing `community` o `experimental` se instala **siempre en estado Deshabilitada y sin ningún permiso concedido**. Solo pasa a Habilitada cuando el administrador concede uno a uno todos los permisos solicitados en la pantalla de consentimiento (siguiente paso). Un listing `verified` instala directamente Habilitada.

Para cada instalación dispones del botón **Permisos**, que abre la pantalla de consentimiento granular donde se revisan y deciden los permisos de esa instalación. Si eres `tenant_admin` verás además dos acciones: **Revocar** (retira la instalación dejándola en estado revocado; el botón se desactiva si ya está revocada) y **Desinstalar** (elimina la instalación por completo). Ambas operaciones se confirman en el servidor, quedan auditadas y la lista se refresca automáticamente. Si el tenant no tiene nada instalado, se muestra el mensaje correspondiente.

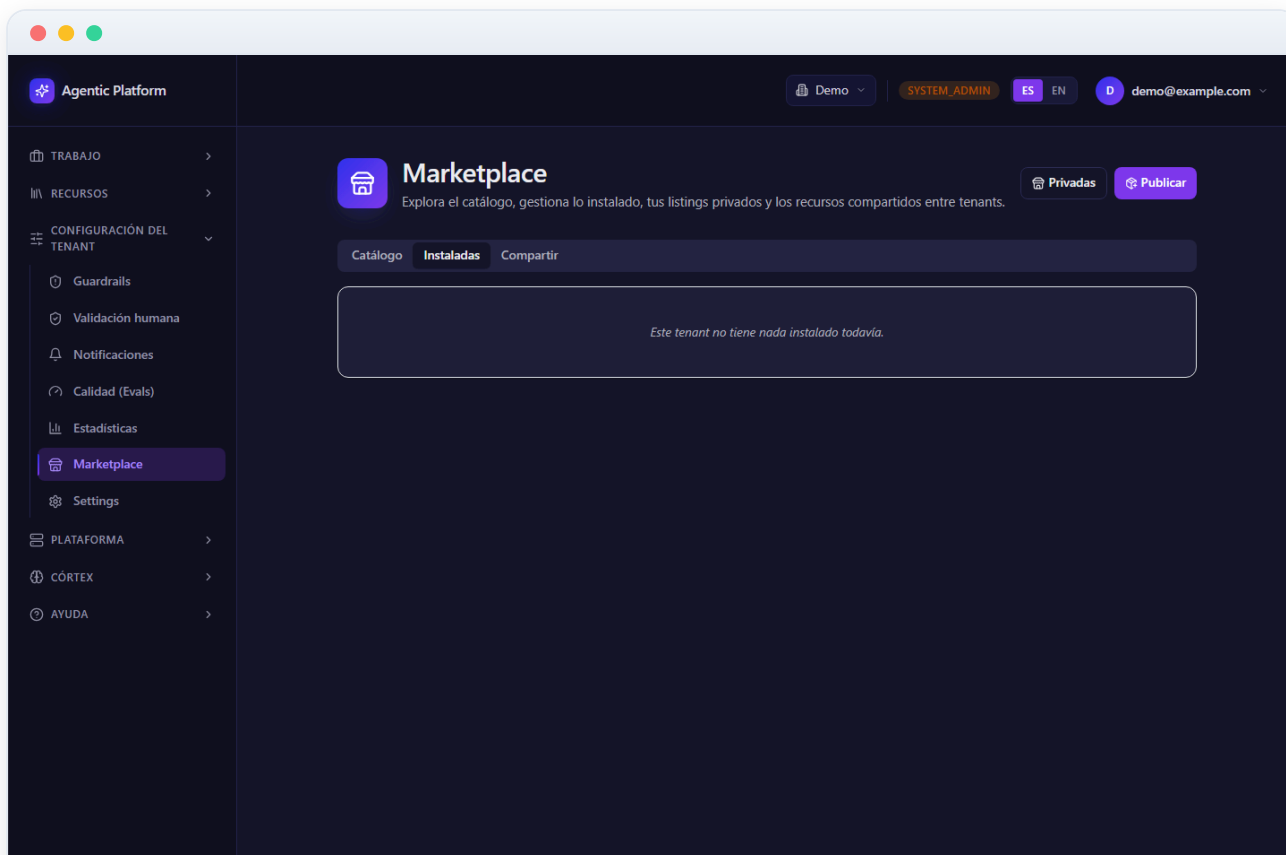


Figura 06.3 — Marketplace: pestaña Instaladas y puertas de la instalación

## 4 Consentimiento granular de permisos de una instalación

La pantalla **Consentimiento de permisos** es donde un tenant\_admin aprueba o deniega, uno a uno, cada permiso que una tool o skill solicita. La cabecera muestra el estado actual de la instalación (**Habilitada**, **Deshabilitada (pendiente de consentimiento)** o **Revocada**). La regla es estricta: una instalación `community` o `experimental` **no se habilita hasta que TODOS los permisos solicitados estén concedidos**; denegar cualquiera de ellos la mantiene deshabilitada. Cada decisión queda auditada en el servidor (acciones `consent` / `consent_denied`). Si el listing es `verified`, la pantalla lo indica con una tarjeta: no requiere consentimiento granular (fricción mínima) y los permisos se aplican según la política de confianza.

Cada permiso solicitado aparece como una tarjeta con su nombre, su estado (**Concedido**, **Denegado** o **Pendiente**), el valor solicitado en fuente monoespaciada y una **ayuda inline** que explica el riesgo real que estás aprobando:

- **Dominios permitidos** ( `allowed_domains` ): la tool solo podrá hacer peticiones HTTP a esos dominios, y siempre a través del proxy de salida de la plataforma — nunca acceso directo a la red.
- **Rutas permitidas** ( `allowed_paths` ): las rutas del workspace a las que la tool tendrá acceso.
- **Política de red** ( `network_policy` ): `none` = sin red; `restricted` = red interna sin salida; `open` = salida a internet **SOLO a través del proxy con allowlist de la plataforma** (registries públicos de paquetes y git). Es clave entenderlo: `open` **no es internet crudo** — todo el tráfico pasa por el proxy con lista blanca y cada uso queda registrado en el audit log.

El flujo de decisión es en dos tiempos: pulsa **Aprobar** o **Denegar** en cada permiso (la decisión queda *en borrador*, marcada con un asterisco «\*» junto al estado) y, cuando tengas todas las decisiones tomadas, pulsa **Guardar decisiones** para enviarlas en lote al servidor. El texto al pie te recuerda cuántas decisiones tienes sin guardar. Tras guardar, la pantalla refleja el nuevo estado de la instalación: si todos los permisos quedaron concedidos, pasa a Habilitada.

Cualquier miembro del tenant puede **leer** esta pantalla; los botones de decisión solo aparecen para tenant\_admin, y el backend impone la misma regla aunque se intentara por API.

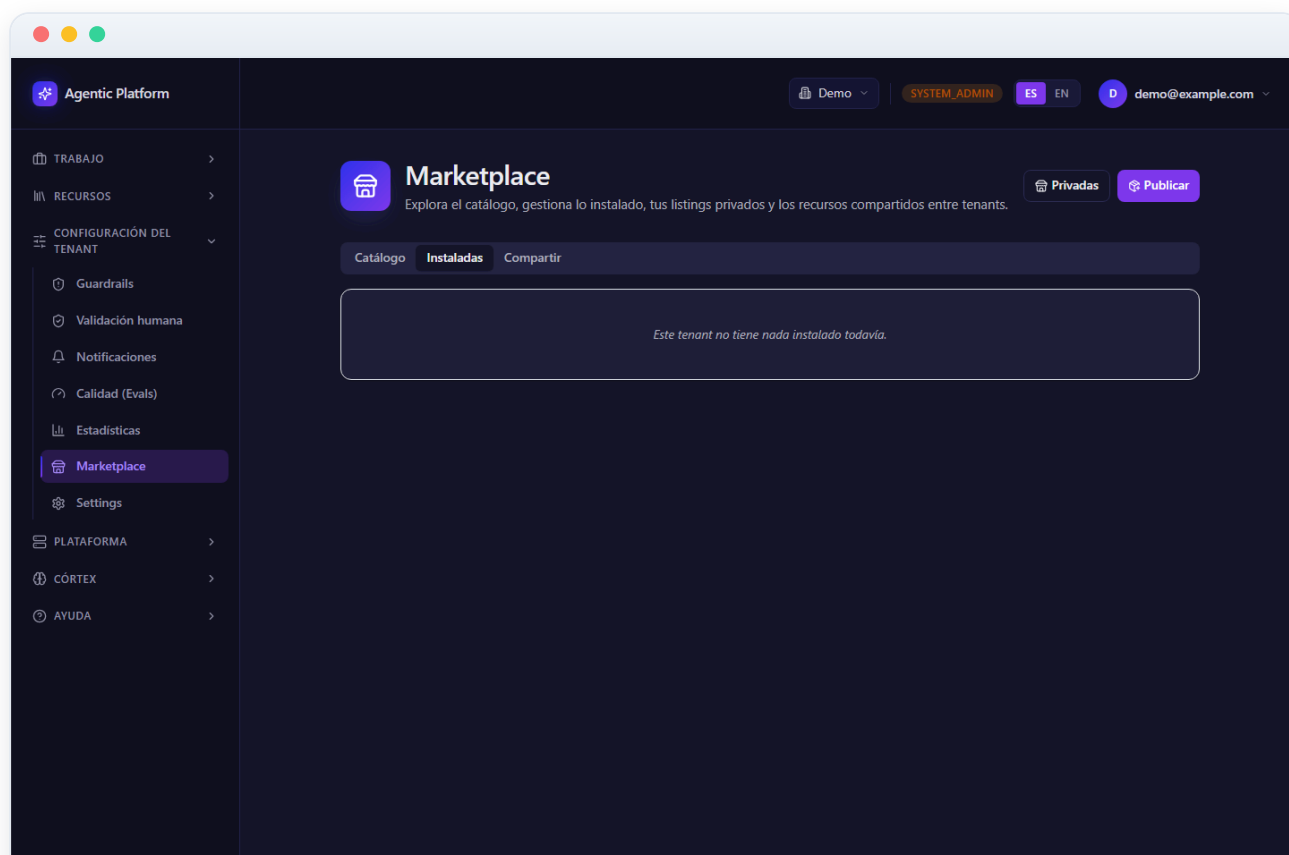


Figura 06.4 — Consentimiento granular de permisos de una instalación

## 5 Marketplace: pestaña Compartir (cross-tenant)

La pestaña **Compartir** gestiona los **grants cross-tenant**: la única vía por la que un listing privado de tu tenant puede llegar a otro tenant. La frontera multi-tenant nunca se relaja de forma implícita: compartir es siempre **opt-in y explícito**, el tenant destino solo ve e instala el listing mientras el grant esté vivo, y cada acción (crear o revocar un share) queda **auditada por el System Admin**. Revocar un grant retira la visibilidad de inmediato.

Si eres `tenant_admin`, en la tarjeta superior puedes crear un grant en tres pasos:

- Selecciona un **Listing privado** del desplegable. Solo aparecen tus listings privados: un listing del catálogo global ya es visible para todos los tenants, así que no hay nada que compartir de él.
- Introduce el **UUID del tenant destino** (te lo debe facilitar el administrador del otro tenant). Compartir con tu propio tenant se rechaza con un error explícito.
- Pulsa **Compartir**. Si algo falla (listing inexistente, tenant destino inválido), el mensaje de error del servidor se muestra bajo el formulario.

Si no tienes listings privados, un aviso te enlaza al Marketplace privado para publicar uno primero. Debajo, la sección **Grants activos creados por tu tenant** lista los shares que has otorgado, indicando el listing y el tenant destino; cada grant tiene un botón **Revocar** para retirarlo al instante. Por defecto no se comparte nada.

Dos garantías de diseño completan el cuadro: un share **nombra** el listing pero no lo copia (el destino siempre lee la versión vigente del origen), y ni las firmas ni ningún secreto viajan por el wire — el listing solo expone el hecho de estar firmado, nunca la firma.

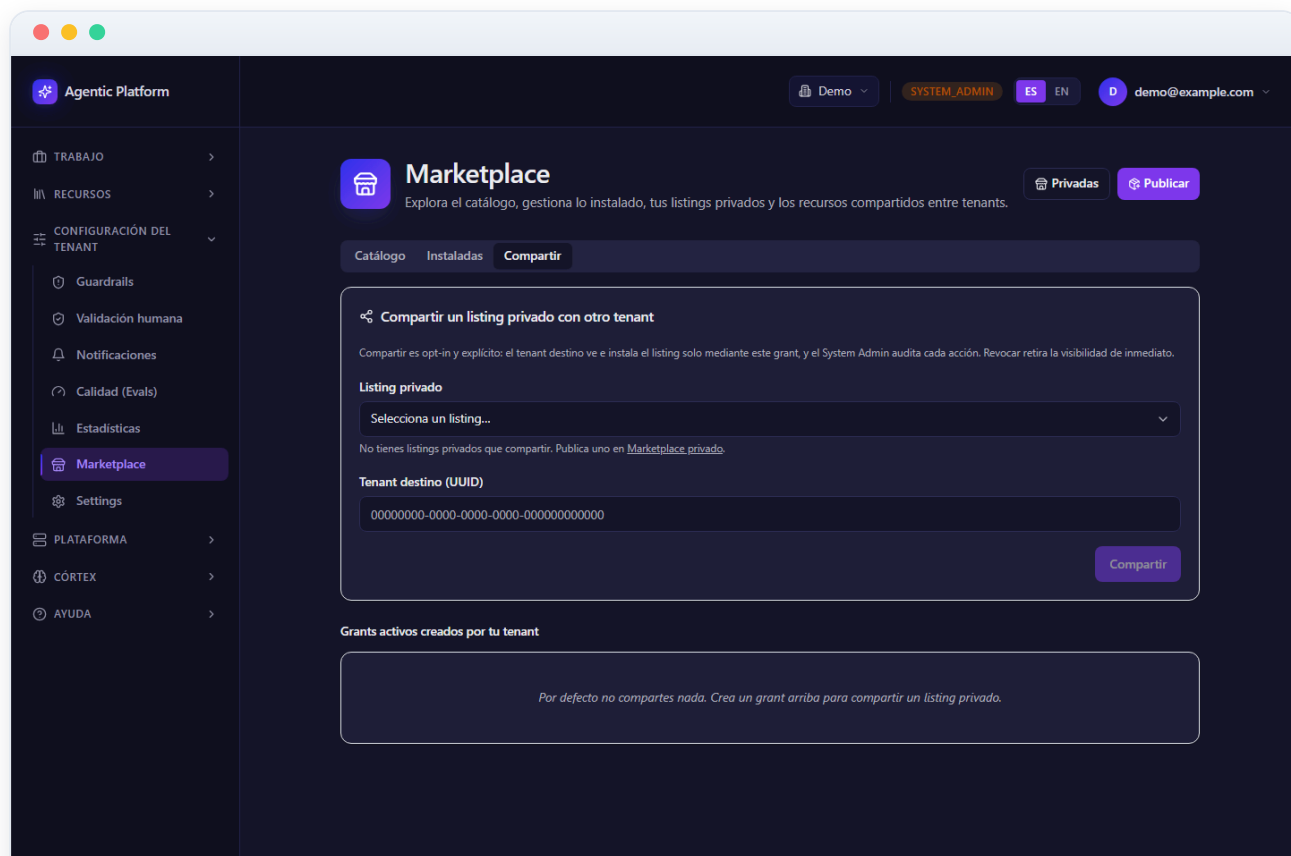


Figura 06.5 — Marketplace: pestaña Compartir (cross-tenant)

## 6 Marketplace privado: publicar un listing (skill)

Esta pantalla permite publicar las skills y tools internas del tenant como **listings privados**: solo tu tenant los ve, aislados por RLS a nivel de base de datos (otro tenant nunca los verá, ni siquiera por API). La cabecera incluye un botón **Volver al catálogo**.

Si eres tenant\_admin verás el formulario **Publicar listing privado**. Primero eliges el **Tipo**: `skill` (documento SKILL.md), `tool` (manifest YAML) o `mcp_server` (manifest YAML con `kind: mcp_server`). Según el tipo, un bloque de ayuda inline muestra el resumen del formato y las listas de campos **obligatorios** y **opcionales** que el validador espera, además de un enlace a la guía de publicación de la documentación.

A continuación rellenas el **Autor** (opcional) y pegas el **Manifest** en el área de texto. El botón **Usar ejemplo** inserta un manifest válido del tipo elegido — un ejemplo que el validador acepta tal cual — para que partas de una base que funciona y la edites (es lo que muestra la captura). El nombre y la versión del listing se leen del propio manifest, no se piden por separado; publicar una versión duplicada de un mismo nombre se rechaza.

Al pulsar **Publicar**, el backend valida el manifest con los parsers de plataforma: si falla, se muestra un recuadro de error con el **mensaje exacto del validador** (qué campo falta o qué está mal formado) y no se crea ningún listing; si tiene éxito, aparece el mensaje «Listing publicado». El nivel de confianza (`community`), la fuente privada y el `tenant_id` se derivan siempre en el servidor — nunca del cliente.

Más abajo, la sección **Catálogo privado del tenant** lista tus listings publicados, cada uno con su tipo, versión, etiqueta `privado` y un botón **Despublicar** (solo tenant\_admin) que lo retira del catálogo. Si aún no hay ninguno, un botón «Empezar con un ejemplo» te precarga el formulario.

The screenshot shows the 'Marketplace privado' interface. The top navigation bar includes 'Agentic Platform', a 'Demo' dropdown, 'SYSTEM\_ADMIN', 'ES', 'EN', and a user profile 'demo@example.com'. The left sidebar has a menu with 'TRABAJO', 'RECURSOS', 'CONFIGURACIÓN DEL TENANT' (with sub-items like Guardrails, Validación humana, etc.), 'Marketplace' (highlighted), 'Settings', 'PLATAFORMA', 'CÓRTEX', and 'AYUDA'. The main content area is titled 'Marketplace privado' and includes a subtitle: 'Publica las skills y tools internas de tu tenant como listings privados. Solo tu tenant las ve; el manifest se valida al publicar.' and a 'Volver al catálogo' button. Below this is the 'Publicar listing privado' form. The 'Tipo' dropdown is set to 'Skill (SKILL.md)'. The form provides instructions on the SKILL.md format and lists required and optional fields. The 'Autor (opcional)' field contains 'Equipo Plataforma'. The 'Manifest' field contains a YAML snippet for an 'internal-reporter' skill. A 'Usar ejemplo' button is present. At the bottom of the form is a 'Publicar' button. Below the form is the 'Catálogo privado del tenant' section, which currently shows a message: 'Este tenant todavía no ha publicado ningún listing privado.' and an 'Empezar con un ejemplo' button.

Figura 06.6 — Marketplace privado: publicar un listing (skill)



## Marketplace privado: formatos de manifest para tool y MCP server

El mismo formulario de publicación se adapta al tipo de manifest elegido. La captura muestra el modo **Tool**, con su bloque de ayuda y su ejemplo insertado. Conviene conocer los tres formatos:

- **Skill (SKILL.md)**: Markdown con un frontmatter YAML entre líneas `---` seguido del cuerpo en prosa. Obligatorios: `name`, `description`, `version` (semver, p. ej. 1.0.0). Opcionales: `dependencies` (lista), `permissions` (`allowed_domains` / `allowed_paths` / `network_policy`) y `examples` (lista de título + prompt).
- **Tool (YAML)**: documento YAML plano, sin cuerpo Markdown. Obligatorios: `name`, `version` (semver), `description`, `entrypoint` (módulo:función) e `implementation.runtime`. Opcionales: `kind` (por defecto tool), `implementation.module` / `implementation.reference`, `dependencies`, `input_schema`, `output_schema` y `permissions`.
- **MCP server (YAML)**: el mismo YAML que una tool pero con `kind: mcp_server` obligatorio y coincidente con el tipo elegido en el desplegable.

Los permisos que declares en el manifest ( `allowed_domains`, `allowed_paths`, `network_policy` con vocabulario `none` | `restricted` | `open` ) son exactamente los que después aparecerán en la pantalla de consentimiento cuando alguien instale el listing: declara solo lo que la tool realmente necesita, porque cada permiso extra es una decisión más que el administrador instalador tendrá que aprobar.

Si el manifest no valida, el recuadro rojo «No se pudo publicar» muestra el mensaje del parser indicando el campo problemático; corrige y vuelve a publicar — no se crea ningún listing hasta que valide.

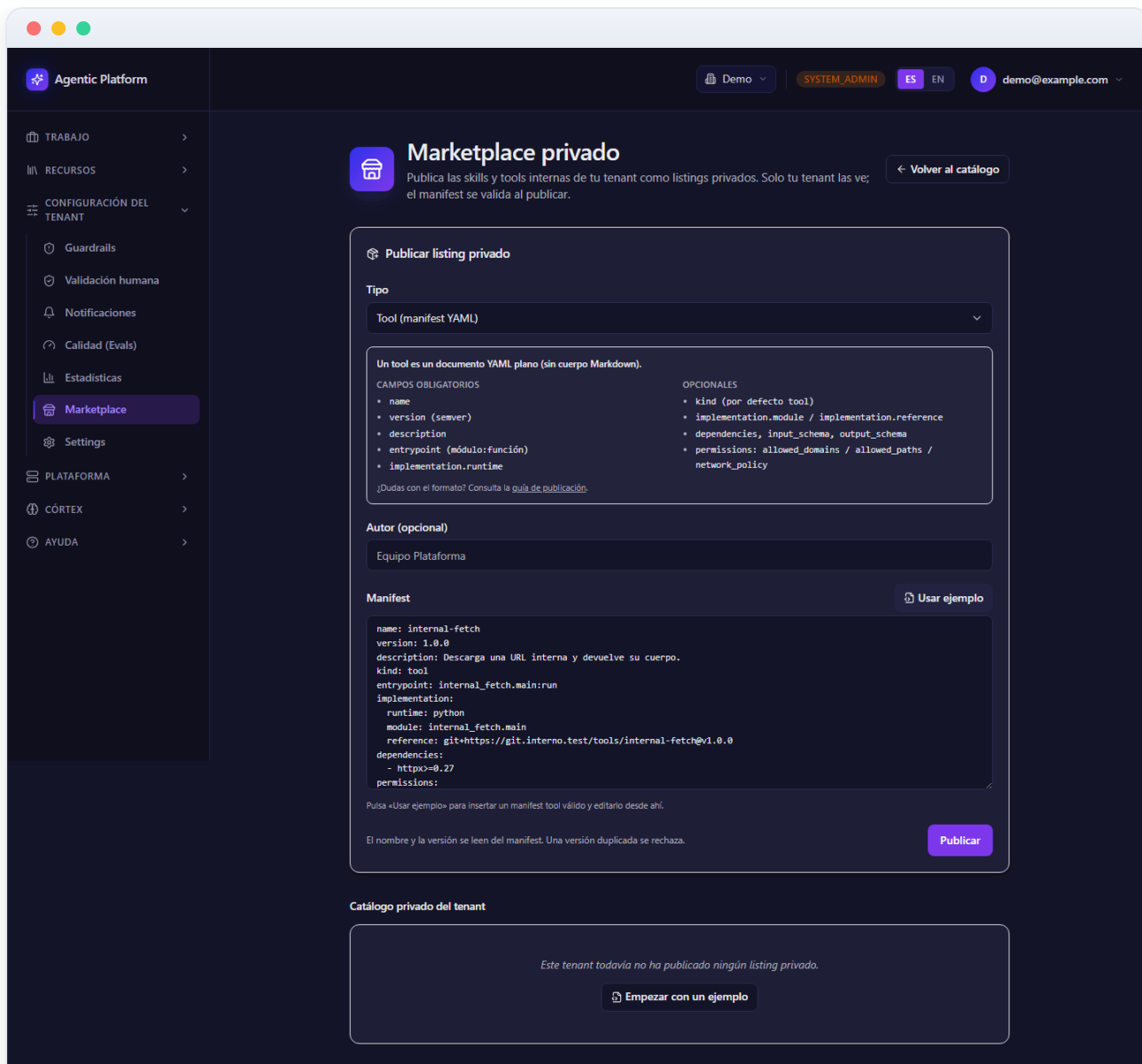


Figura 06.7 — Marketplace privado: formatos de manifest para tool y MCP server

## 8 Dashboard de Guardrails

El dashboard de **Guardrails** ofrece observabilidad de las políticas de seguridad declarativas que se disparan sobre el trabajo de tu tenant: detección de secretos, PII, contenido bloqueado, etc. Los guardrails se evalúan en cuatro puntos del ciclo de cada agente — `pre_llm`, `post_llm`, `pre_tool` y `post_tool` — y cada disparo queda registrado como un evento tenant-scoped. Es una vista solo para **tenant\_admin**; sin ese rol verás un aviso indicando que lo necesitas.

Una garantía de privacidad preside la pantalla: el detalle de cada evento está **enmascarado en origen**. El secreto o dato personal que disparó el guardrail **nunca se almacena** — el registrador lo enmascara antes de persistir —, por lo que este dashboard jamás puede mostrar el valor crudo, ni siquiera a un administrador.

La estructura de la pantalla, de arriba abajo:

- **Ventana:** selector temporal de 7, 30 o 90 días que reencuadra todos los números.
- **Eventos:** tarjeta con el total de eventos de la ventana, junto a la **Tendencia diaria** representada como un sparkline (línea plana si no hubo eventos).
- **Por tipo y Por severidad:** dos desgloses en barras horizontales con su recuento. La severidad se ordena de `critical` a `info`, cada una con su color.
- **Eventos recientes:** tabla con el tipo de guardrail, el hook donde saltó, la severidad, la **acción aplicada** — bloquear, enmascarar, avisar, reintentar (con feedback al agente), escalar (a humano) o transformar —, el detalle enmascarado y la marca temporal.

Usos típicos: detectar un pico de eventos tras desplegar un cambio de prompts, identificar qué tipo de guardrail está frenando más trabajo, o verificar que una política recién configurada realmente se está disparando. Si un guardrail crítico se dispara con frecuencia, revisa la configuración del proyecto afectado antes de relajar la política.

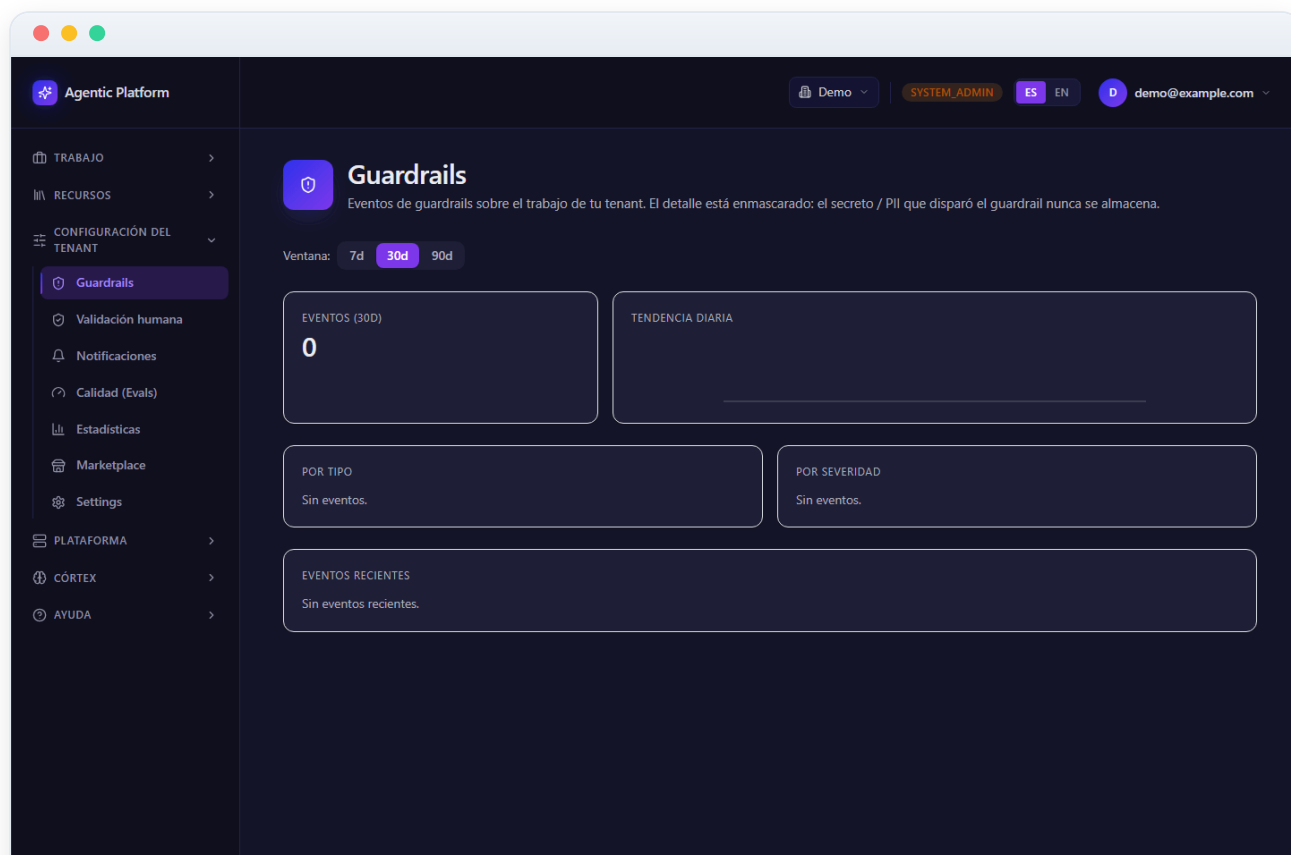


Figura 06.8 — Dashboard de Guardrails

## 9 Dashboard de Calidad (Evals)

El dashboard de **Calidad (Evals)** muestra cómo puntúan los agentes de tu tenant a lo largo del tiempo, agregado desde las ejecuciones de evaluación (runs de evals con juez LLM sobre datasets golden). Es una vista solo para **tenant\_admin**; sin ese rol verás un aviso indicándolo. Todo es tenant-scoped: solo ves tus propios runs y resultados — la comparativa entre tenants es una superficie aparte reservada al System Admin.

Arriba hay un selector de **Ventana** (30, 90 o 365 días). A continuación, tarjetas de cabecera con el **Pass rate** global de la ventana (porcentaje de ítems de evaluación superados) y el número de **Runs**, más un sparkline con la **Tendencia de pass rate diaria**.

Después se presentan cuatro desgloses en barras de porcentaje, cada una con su pass rate y el detalle de ítems superados sobre el total (p. ej. 18/20):

- **Por agente:** qué agente rinde mejor o peor; útil para detectar un agente cuyo rol o prompt necesita revisión.
- **Por release de prompt:** compara versiones de prompt entre sí — la vista clave para validar que una nueva release no degrada la calidad antes de generalizarla.
- **Por dataset (benchmark):** el rendimiento sobre cada banco de pruebas golden del tenant.
- **Por criterio:** el pass rate de cada criterio individual del juez (corrección, formato, seguridad...), que localiza *en qué* falla un agente y no solo *cuánto*.

Al final, la tabla **Historial de runs** lista las últimas ejecuciones con su dataset, agente, release de prompt, estado (completado, en ejecución, pendiente, fallido o cancelado), pass rate con su fracción, coste en USD y fecha de finalización. Una nota al pie recuerda que los costes se muestran en **USD canónico**: la conversión a la moneda del tenant depende del sistema de tipos de cambio, aún no disponible.

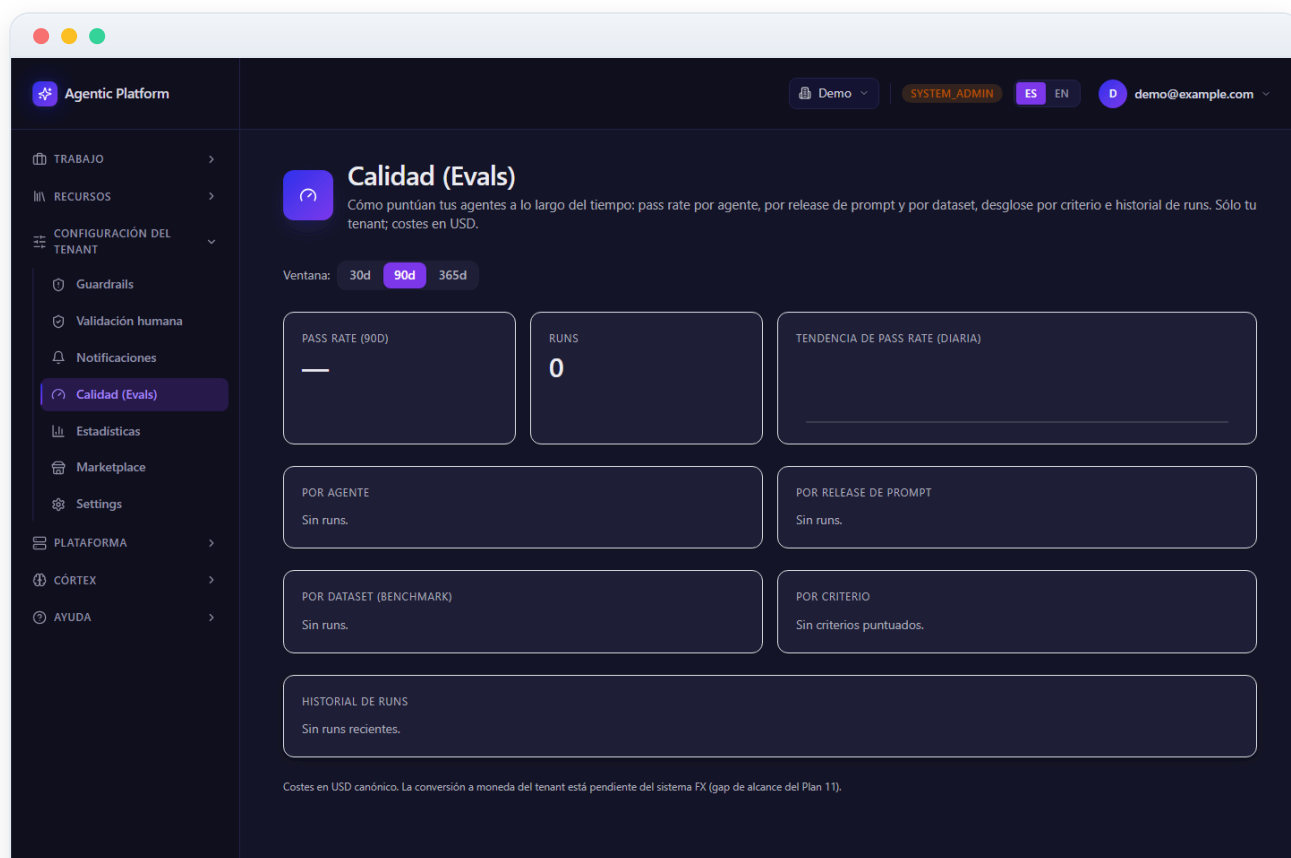


Figura 06.9 — Dashboard de Calidad (Evals)